

Visual Attention and Learning Effects in Shoulder-Surfing: A Human-Factors Perspective on PIN Observation

Anonymous

Abstract

This study examines how environmental conditions, perceptual constraints, and user characteristics influence the success of shoulder-surfing attacks during 4-digit PIN entry. A controlled laboratory experiment involving 1,080 observation trials systematically varied lighting conditions, shielding techniques, observer demographics, and repeated exposure. Observers attempted to reconstruct PINs after each trial, and performance was analyzed using statistical methods. The findings show that attack success is strongly shaped by contextual and human factors. Bright outdoor lighting reduced observation accuracy, whereas physical shielding significantly decreased successful inference, with fixed hoods providing the greatest protection. Observers with higher technical familiarity achieved better performance, and repeated exposure led to rapid improvement, indicating pronounced learning effects. These patterns suggest adaptive visual attention strategies and increasing efficiency in extracting critical cues. The results demonstrate that shoulder surfing is both context-dependent and quickly learnable, highlighting the role of perceptual and cognitive processes in security-compromising behavior. The study contributes to human-centered cybersecurity research by informing the design of authentication systems that account for environmental variability and user behavior while supporting effective and usable countermeasures.

Keywords: Keyboards, Touch screens, Cybersecurity, Experience, Illumination

1. Introduction

1.1. What is Shoulder-surfing

Shoulder-surfing attacks, as defined in the MITRE CAPEC-508 taxonomy (MITRE, 2025), aim to recover a user’s authentication credentials—such as a Personal Identification Number (PIN), password, or unlock gesture. The phenomenon has been studied empirically since the early 2010s. The threat and its implications have been widely analyzed in the literature, e.g., (Bošnjak & Brumen, 2019; Kwon & Hong, 2015) and are commonly included among standard adversarial techniques (Herland et al., 2016). Prior work therefore often focuses on specific applications of shoulder-surfing, such as eavesdropping on pairing keys for device pairing (Zhao et al., 2021), mobile device unlocking (Ku et al., 2019; Shahzad et al., 2017), and conventional keyboard entry without built-in countermeasures (Wan et al., 2024; Zhou et al., 2023). Alternative defenses and interaction paradigms have also been proposed, including device-specific shaking gestures (Zhu et al., 2017), one-time PIN mechanisms (Binbeshr et al., 2023), circlePIN for smartwatch authentication (Chefrou et al., 2024), dynamic graphical grid techniques (Gong et al., 2024), personal image-based password schemes (Sosa Valles et al., 2018), and other graphical approaches and their evaluations (Lopez et al., 2015; Por et al., 2024; Nizamani et al., 2021), some of which target specific form factors such as touchscreens (Wu et al., 2024; Alhothaily et al., 2017). All these efforts seek to eliminate or at least reduce the probability of successful observation attacks (Sun et al., 2018). Consequently, continued study of shoulder surfing remains justified.

The literature classifies shoulder-surfing into several types (De Luca et al., 2010):

- *Direct visual attack* – the attacker is physically present near the victim and observes the input directly.
- *Indirect visual attack* – carried out using recorded footage (e.g., CCTV, hidden cameras, smartphone video).
- *Mirror/reflective attack* – the attacker observes credentials via reflections (e.g., windows, eyeglasses, glossy surfaces).
- *Assisted attack* – the attacker uses technology to magnify or slow down the user’s finger movements.

- *Repeated observation attack* – the attacker repeatedly observes the same user to analyze patterns and habits.

The success rate of a shoulder-surfing attack is influenced by multiple factors. Industry reports from cybersecurity firms summarize empirical findings and offer defensive guidance, e.g., (McAfee, 2025; NordVPN, 2025).

- *Observer-user distance* – accuracy increases as the observer moves closer the user.
- *Viewing angle* – optimal observations typically occur from directly behind the user.
- *Display lighting and contrast* – a bright screen viewed in dim ambient light is easier to read.
- *Input style* – slow or highly predictable input behavior increases exposure to observation.
- *Observer experience* – repeated attempts and repeated exposure substantially improve an observer’s success rate.

1.2. Research Gap

Despite extensive prior work on observation angles, viewing geometry, graphical-password visibility, and device-specific countermeasures, no study to date has systematically examined how environmental visibility, physical shielding, demographic perceptual differences, and attacker learning jointly shape shoulder-surfing performance in a controlled, fully crossed human-factors experiment. Existing research typically isolates one or two of these variables or relies on video-based laboratory setups that do not reflect real-time perceptual demands. The present study addresses this gap by integrating user-side and observer-side factors into a single experimental framework that directly measures how situational conditions, shielding behaviors, and cognitive-perceptual capabilities influence the likelihood and severity of PIN exposure. This provides a more comprehensive basis for understanding real-world risks and for informing the design of authentication interfaces resilient to visual observation.

Addressing this gap requires systematic analysis of four factors that theory and prior research suggest fundamentally shape visual-acquisition performance: environmental visibility, physical shielding, observer characteristics, and short-term perceptual learning.

Each of the four variables examined in this study is both theoretically grounded and empirically supported in the human-factors and usable-security literature. Lighting affects visual-information quality and cue salience (Johansson, 1973; Kaczmarek et al., 2016); physical shielding occludes key motion trajectories required for PIN inference (Tari et al., 2006; Aviv, A. J., Wolf, F., & Kuber, R., 2018); observer age and expertise influence visual-processing speed and attentional performance (Verghese, 2001; Kwon et al., 2013); and repeated exposure is known to produce rapid perceptual learning in credential-observation tasks (Tari et al., 2006; Khan et al., 2018). While some of these effects may appear intuitive, prior research demonstrates that they arise from distinct perceptual and cognitive mechanisms, underscoring the theoretical importance of examining them systematically and in combination. By analyzing them jointly in a fully crossed design, the present study advances understanding beyond intuitive expectations and provides a more rigorous human-factors account of visual credential acquisition.

1.3. Contributions and Relevance to CHBR

Computers in Human Behavior Reports publishes research on how people interact with digital technologies, including human factors, user behavior, usability, and the privacy–security implications of interactive systems. Our work contributes to the human-factors perspective on privacy and security by quantifying how perceptual and contextual conditions shape the real-time interpretability of everyday PIN-entry interactions on public terminals and payment devices.

The study explicitly addresses the security–usability–accessibility trade-off inherent in these interactions under variable real-world conditions (lighting, occlusion, and attacker learning), providing design-relevant evidence for interface, enclosure, and deployment decisions in public terminals, self-service kiosks, and payment devices. It also contributes empirical evidence on user/attacker behavior and age-related differences by testing how observer demographics and short-term learning affect performance.

1.4. Related Work

Existing studies on shoulder surfing predominantly focus either on the security of specific authentication mechanisms or on computational methods for detecting potential observers. For example, Bâce, M., Saad, A., Khamis, M., Schneegass, S., & Bulling, A. (2022) provide one of the most detailed analyses of observation angles and distances to date, but their work is limited

to three content types and does not address environmental factors such as lighting or shielding. Similarly, Schneegass et al. (2022) investigate shoulder surfing “in the wild”, highlighting its opportunistic nature but without experimentally isolating how perceptual or behavioral conditions shape attacker performance.

Our study extends this line of work by systematically manipulating lighting conditions, shielding, observer demographics, and learning effects across 1,080 controlled trials—variables that have not been previously examined in combination.

2. Research Goals and Structure

The main objective of this research is to analyze and quantify the vulnerability of modern PIN-entry authentication techniques, such as ATM keypads and payment terminals to shoulder-surfing attacks. The study adopts a dual-perspective approach that distinguishes between user-centric and attacker-centric factors influencing overall risk. While most prior studies address only isolated elements of the problem or cannot ensure systematic results (Wiese & Roth, 2015), this research integrates both perspectives into a more comprehensive experimental framework. This study focuses specifically on a subset of knowledge-based authentication methods that are susceptible to shoulder surfing: conventional PIN entry, which remains widely used for payment authorization and as a fallback authentication method when biometrics fail.

2.1. User-Centric View and Measures

User-side factors influence the amount and clarity of visual information available to nearby observers during PIN entry. Prior work shows that users often attempt to shield the keypad or reduce exposure of fine finger movements, although these behaviors vary widely in effectiveness (Adams & Sasse, 1999; von Zezschwitz et al., 2015). Even simple occlusion—such as covering part of the keypad—can restrict the visibility of digit locations or trajectories, reducing the diagnostic cues needed for reconstruction (Tari et al., 2006).

Environmental conditions further shape users’ vulnerability. Changes in ambient lighting, reflections, and screen contrast influence how easily fine motions can be tracked by bystanders (Khamis et al., 2018). These situational factors alter cue salience without requiring any action from the user,

and they often vary unpredictably across public settings such as ATMs or payment terminals.

Understanding these user-side determinants is essential for assessing the protective value of common behaviors (e.g., hand shielding) and contextual factors (e.g., lighting), both of which modulate the perceptual information exposed to observers.

2.2. Attacker-Centric View and Measures

Observer performance depends on perceptual, cognitive, and experiential factors that govern how available cues are interpreted. Studies show that attackers integrate multiple motion-based indicators—including relative trajectories and temporal rhythm—to infer PINs even under partial occlusion (Khan et al., 2018; Vergheze, 2001). This process resembles a real-time visual inference task rather than simple detection.

Viewing geometry also plays a critical role. Laboratory studies show that PIN entry can be inferred from a broad range of angles and distances, with high success even from lateral positions (Bâce, M., Saad, A., Khamis, M., Schneegass, S., & Bulling, A., 2022; Aviv et al., 2015). Naturalistic studies further indicate that users often misjudge when observers occupy advantageous vantage points (Schneegass et al., 2022; Harbach et al., 2014).

Experience and repeated exposure substantially enhance attacker proficiency. Prior work documents rapid performance gains across successive observations for PINs, pattern locks, and graphical passwords (Tari et al., 2006; Aviv, A. J., Budzitowski, D., & Kuber, R., 2017; Khan et al., 2018). Understanding this experiential component is critical for modeling realistic attack capability beyond one-off opportunistic events.

2.3. Paper Structure

This paper is structured to support a comprehensive human-factors analysis of PIN-entry vulnerability. Section *Method* formulates the four research questions (RQ1–RQ4) and associated hypotheses (H1–H4), derived from both the user-centric and attacker-centric perspectives. It also details the experimental design, including the operationalization of environmental variables (lighting), physical protective behaviors (hand shielding and fixed hoods), and observer characteristics (age and domain experience). The section further specifies the task structure, observation protocol, and data-collection procedures used to ensure research ethics, internal validity and ecological relevance.

Section *Results* presents the empirical results from 1,080 observation trials. For each hypothesis, it reports the statistical analyses and interprets the findings in terms of perceptual performance, information-acquisition constraints, and changes in attacker effectiveness over repeated exposures. Both full-match and partial-match outcomes are analyzed to reflect real-world gradients of risk.

Section *Discussion* integrates these findings into a broader human-factors discussion. It outlines implications for interface design, environmental layout, user with repeated exposure, and protective behaviors, emphasizing how perceptual load, situational awareness, and interaction dynamics shape susceptibility to shoulder-surfing attacks. The section concludes with identified limitations—such as constraints on generalizability and contextual variability—and proposes directions for future research aimed at improving the ergonomic and security properties of PIN-based authentication systems.

3. Method

3.1. Research Questions and Hypotheses

To systematically evaluate the factors that modulate observer performance during shoulder-surfing attempts, the study formulated the following research questions:

RQ1 — Environmental Visibility Conditions Do lighting conditions, e.g., overcast daylight, direct sunlight, nighttime illumination, affect the probability that an observer can correctly infer a full or partial PIN?

RQ2 — Physical Shielding and Interface Occlusion To what extent do common user-initiated or device-embedded shielding behaviors (open entry, hand coverage, fixed hood) reduce the availability of diagnostic visual cues and thereby lower observation success rates?

RQ3 — Observer Demographics and Perceptual Capabilities Do demographic characteristics—particularly age and technology-related experience—systematically influence observer performance during visual credential-acquisition tasks?

RQ4 — Repeated Exposure Does attacker proficiency improve over short-term repeated observations, indicating the presence of rapid perceptual learning or strategy refinement?

3.2. Research Hypotheses

Based on the four research questions, the following hypotheses specify expected effects of environmental, behavioral, and observer-related variables on PIN-observation performance. Each hypothesis reflects underlying human-factors mechanisms such as cue visibility, perceptual discriminability, and the cognitive resources required to infer touch-input sequences. While our design focused on identifying main effects, the selected variables are also theoretically expected to interact; environmental visibility may amplify or attenuate the effectiveness of shielding, and observer experience may moderate the influence of both lighting and occlusion. These interdependencies offer additional motivation for examining each factor independently as a first step.

3.2.1. H1 — Effect of Lighting Conditions

H1₀ (Null) Lighting conditions do not significantly affect observer performance; the probability of successful PIN inference is independent of illumination.

H1₁ (Alternative) Lighting conditions significantly influence observer performance, with suboptimal visibility—particularly direct sunlight—reducing the discernibility of finger trajectories and keypad locations.

3.2.2. H2 — Effect of Physical Shielding

H2₀ (Null) Physical shielding (hand coverage or fixed hood) does not significantly alter observation outcomes.

H2₁ (Alternative) Physical shielding significantly reduces the availability of diagnostic visual cues, leading to lower full and partial PIN-reconstruction rates.

3.2.3. H3 — Effect of Observer Demographics

H3₀ (Null) Observer demographic characteristics—particularly age and professional background—do not significantly influence performance.

H3₁ (Alternative) Younger observers and those with technology-oriented experience exhibit higher perceptual acuity or task familiarity, resulting in increased PIN-observation success.

3.2.4. *H4 — Effect of Repeated Exposure*

H4₀ (Null) Repeated exposure to PIN-entry observations does not produce measurable improvement.

H4₁ (Alternative) Repeated exposure leads to rapid perceptual learning and strategy refinement, improving the observer’s ability to infer PINs over successive trials.

3.3. *Ethical Approval and Data Protection*

All procedures involving human participants were conducted in accordance with relevant institutional and national guidelines. Participation was voluntary, and all participants provided informed consent prior to the experiment.

No personal or sensitive authentication data were collected during the study. In particular, participants never entered their own real PINs; all PINs used in the study were system-generated random sequences unrelated to any personal or financial accounts. No video or audio recordings were made. Observers recorded only their own written responses, and all data were anonymized at the point of collection such that results cannot be linked to individual participants.

Per the host institution’s ethics policy, formal ethics committee approval was not required because the study did not involve the collection of sensitive personal data. Nevertheless, the study followed the principles of the Declaration of Helsinki.

3.4. *Experimental Design Overview*

The experiment was designed to *systematically evaluate how environmental visibility, physical shielding, observer demographics, and repeated exposure affect the success of unaided, real-time visual reconstruction of PIN entries*. A fully crossed design was used, combining:

- *4 lighting conditions:* overcast daylight, direct sunlight, nighttime illumination, indoor ATM lighting
- *3 shielding conditions:* open entry, hand shielding, fixed ATM-style hood

- *2 input devices*: mechanical ATM keypad and touchscreen terminal
- *2 observer positions*: behind the entrant ($\pm 30^\circ$) and lateral ($80\text{--}90^\circ$)
- *3 repeated observation iterations* per condition pair
- *2 demographic groups* (younger/technical vs. mixed/older)

Across all combinations and iterations, the study produced *1,080 real-time observation attempts*.

3.5. Threat Model

The study models a typical *opportunistic shoulder-surfing scenario* where an unaided human observer attempts to infer a PIN from a single viewing angle without physical repositioning or technological support. Observers:

- viewed the entry *with naked eyes only*,
- remained *static* at a predefined location,
- had *no access* to slow-motion, replay, zoom, or enhanced visibility tools,
- could not use reflective surfaces or change viewing geometry.

This models common real-world contexts such as payment terminals, ATM queues, or crowded public spaces, where attackers must rely solely on momentary visual information.

3.6. Participants

Nine participants served as observers (attackers). To assess demographic and experience-related effects, they were divided into two predefined groups:

- *Group A* ($n = 5$): ages 21–32; secondary or university education; all employed in banking or technology sectors
- *Group B* ($n = 4$): ages 21–77; mixed vocational/secondary education; including two working adults, one student, one retiree

This grouping enabled comparative analysis of age-related visual performance, attentional flexibility, and familiarity with authentication interfaces.

A single trained research assistant, not counted among the observer participants, *performed all PIN entries* to ensure that finger trajectories, speed, and movement patterns were consistent across trials—eliminating user-input variability as a confounding factor. All nine observers completed all conditions; no data were excluded.

3.7. Materials and Apparatus

Two commercially common PIN-based authentication devices were used:

1. *Mechanical ATM-style keypad* (12-key numeric layout)
2. *SumUp Solo touchscreen payment terminal*

Not a product evaluation. We used the SumUp Solo as a representative of common touchscreen payment terminals; we do *not* evaluate its commercial design quality.

The touchscreen terminal was selected as a representative example of a widely deployed, small-form-factor payment device with on-screen PIN entry, instantiated here to represent the interaction class of handheld tabletop payment terminals (i.e., a glare-prone touchscreen with direct finger input) in a controlled experiment.

Lighting conditions were established using natural outdoor illumination (overcast, direct sunlight, nighttime) and the fixed ambient lighting of an indoor ATM vestibule.

Shielding conditions were implemented as follows:

- *Open entry*: full visibility of keypad and finger motion
- *Hand shielding*: partial occlusion by the entrant's non-dominant hand
- *Fixed hood*: use of ATM's structural privacy hood restricting top-down visibility

Observer positions were marked on the ground to standardize viewing angle and distance:

- *Position I*: behind entrant, approx. 1.5 m, within a $\pm 30^\circ$ cone
- *Position II*: lateral right-side position, approx. 1.5 m at $80\text{--}90^\circ$

3.8. Procedure

Each trial followed the same standardized structure:

1. A *random 4-digit PIN* was generated by the experimenter.
2. The trained entrant entered the PIN on one of the two devices, under a specific lighting $\times$ shielding condition.

3. The observer watched the entry from the assigned viewing position, without movement.
4. Immediately after each attempt, the observer wrote down the perceived PIN.
5. A trial was scored as:
 - *Full match*: all 4 digits correct, in order
 - *Partial match*: exactly 3 digits correct and in correct positions
 - *No match*: all other outcomes
6. No trial could be replayed; observers saw each entry once, in real time.

Each observer completed *3 repetitions* for every condition combination. Conditions were *counterbalanced* to mitigate order effects and minimize sequential learning tied to specific lighting or shielding states.

3.9. Total Trial Structure and Data Volume

The full dataset consisted of:

- *9 observers*,
- *4 lighting conditions*,
- *3 shielding conditions*,
- *2 input devices*,
- *2 observer positions*,
- *3 iterations*

yielding: $9 * 4 * 3 * 2 * 2 * 3 = 1,080$ observation attempts.

Each datapoint corresponds to a single real-time visual inference attempt and includes:

- *environmental condition*,
- *shielding method*,
- *input device*,

- *viewing angle,*
- *observer group,*
- *trial iteration,*
- *full/partial/no match outcome.*

This experimental structure enables robust statistical analyses for all four hypotheses.

3.10. *Dependent and Independent Variables*

Independent variables:

- *Lighting, condition*
- *Shielding method,*
- *Input device,*
- *Observer position,*
- *Demographic group,*
- *Trial iteration.*

Dependent variables:

- *Binary full-match success*
- *Binary partial-match success*
- *Combined “successful inference” rate (full + partial)*

3.11. *Statistical Approach*

Hypotheses were evaluated using *chi-square tests of independence*, consistent with categorical outcome data.

Where appropriate, effect sizes, observed frequencies, and confidence intervals are reported.

Given the medium-to-large effects reported in prior shoulder-surfing studies (Tari et al., 2006; Aviv, A. J., Wolf, F., & Kuber, R. , 2018), a dataset of 1,080 observations provides *sufficient statistical power ($> .80$) to detect effects* of comparable magnitude in a chi-square framework.

3.12. Results

This section reports the empirical findings from 1,080 PIN-observation attempts. The complete raw experimental dataset containing all variables for 1,080 observations is attached as *Experimental Data.xlsx*.

For each hypothesis (H1–H4), we present the observed frequencies, statistical tests, and human-factors interpretation of performance effects. Both complete and partial matches are included in the “successful” category, as partial correctness still represents a substantial security risk.

3.12.1. H1: Effect of Lighting Conditions

Table 1 summarizes the relationship between lighting and observation success (visualized in Figure 1).

Table 1: Observation success by lighting condition.

Lighting condition	Successful / partial	Unsuccessful	Total
Overcast	166	104	270
Direct sunlight	131	139	270
Nighttime	167	103	270
ATM inside	176	94	270
Total	640	440	1080

A chi-square test of independence showed a significant effect of lighting,

$$\chi^2(3, N = 1080) = 14.7, p < .01$$

The associated effect size was small (Cramer’s $V = .12$), indicating that while lighting significantly affected success rates, its *relative influence was modest compared to other factors examined in this study*.

Direct sunlight produced the lowest success rate (48.5%), consistent with reduced contrast and increased glare. Overcast, nighttime, and indoor conditions yielded substantially higher visibility (61–65%). As illustrated in Figure 1, these findings confirm H1, indicating that lighting materially affects the perceptual availability of movement and contact cues during PIN entry.

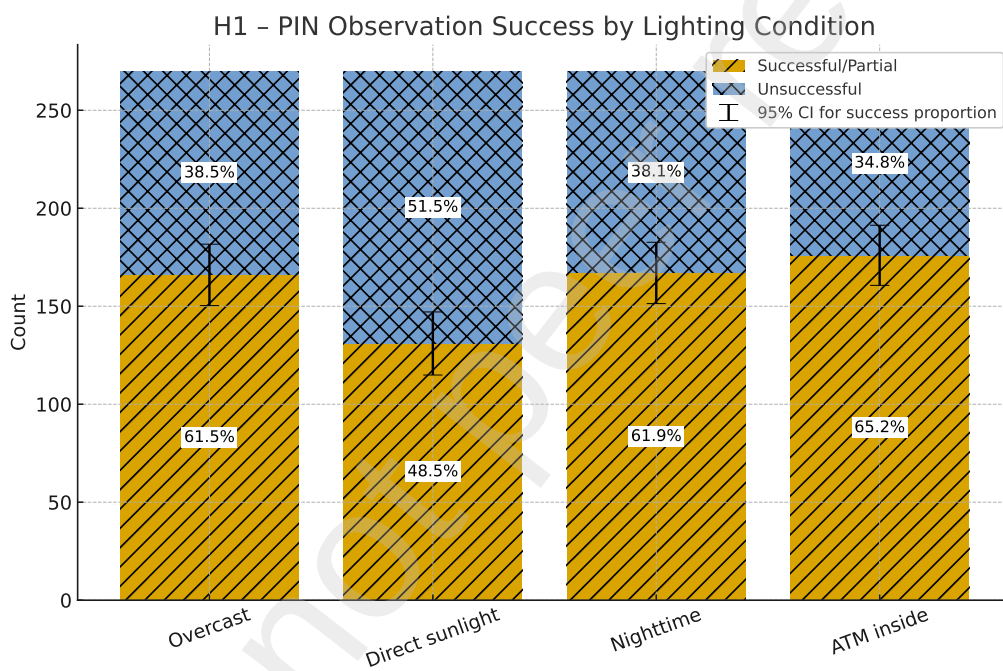


Figure 1: Observation success by lighting condition (normal-approximation confidence intervals).

3.12.2. H2: Effect of Physical Shielding

Observation success by shielding type is presented in Table 2 and visualized in Figure 2.

Table 2: Observation success by shielding type.

Shielding type	Successful / partial	Unsuccessful	Total
No shielding	325	107	432
Hand cover	236	196	432
Fixed hood	79	137	216
Total	640	440	1080

A chi-square test revealed a strong effect of shielding,

$$\chi^2(2, N = 1080) = 95.45, p < .001$$

The effect size was large (Cramer's $V = .30$), consistent with the strong and systematic reduction in observation success under increasing levels of occlusion. Shielding thus represents the *most influential user-side protective factor* in the experiment.

Success rates decreased systematically with increasing occlusion:

- 75.2% — No shielding
- 54.6% — Hand cover
- 36.6% — Fixed hood

As shown in Figure 2, these results strongly support H2 and demonstrate that restricting the observer's access to finger trajectories and touch locations significantly reduces inference performance.

3.12.3. H3: Effect of Observer Age Group

Table 3 shows performance differences across age groups, with the corresponding visualization provided in Figure 3.

A chi-square test indicated a significant association between age group and performance,

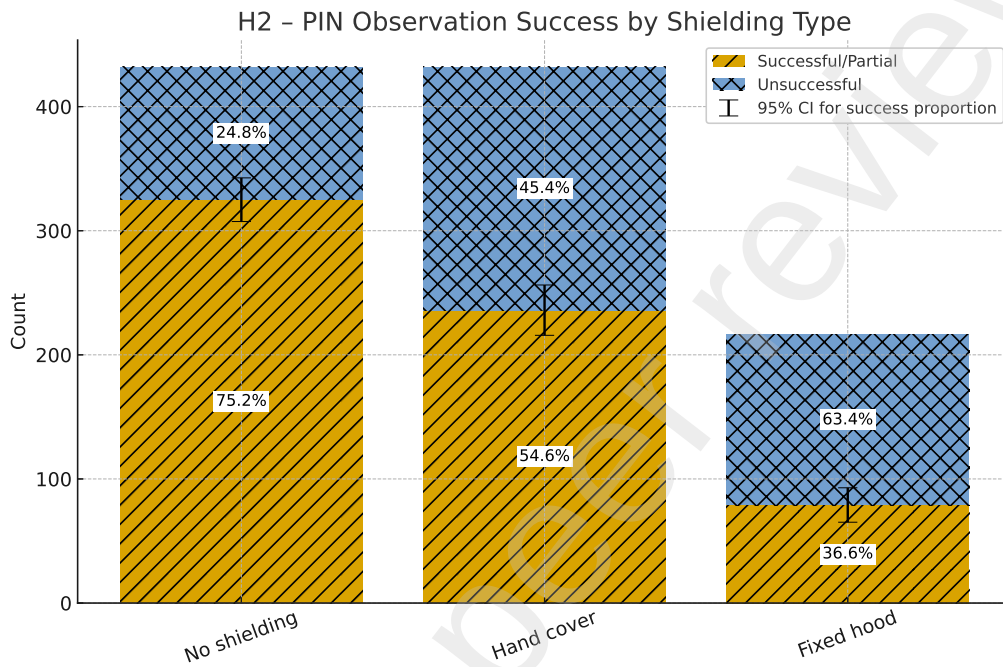


Figure 2: Observation success by shielding type (normal-approximation confidence intervals).

Table 3: Observation success by observer demographic group.

Observer group	Successful / partial	Unsuccessful	Total
Group A (Younger)	389	211	600
Group B (Average age)	251	229	480
Total	640	440	1080

$$\chi^2(1, N = 1080) = 17.41, p < .001$$

The effect size was small-to-medium (Cramer's $V = .13$), suggesting that demographic differences played a *noticeable but not dominant role* in shaping perceptual performance.

Group A (younger, technology-oriented individuals) achieved a success rate of 64.8%, compared to 52.3% in Group B. As depicted in Figure 3, these results confirm H3 and align with known differences in visual processing speed and attentional flexibility.

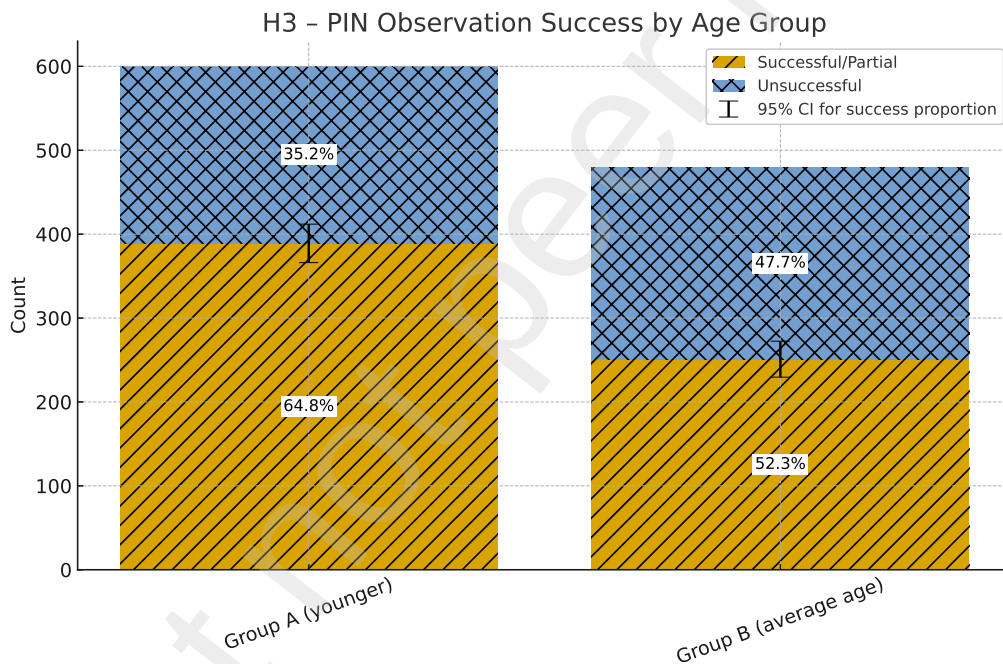


Figure 3: Observation success by observer demographic group (normal-approximation confidence intervals).

3.12.4. H4: Effect of Repeated Exposure

Repeated exposures led to clear improvements in observer performance, visualized in Figure 4 (learning curve).

Success rates increased from 50.6% in the initial observation to 66.7% by the third iteration in this sample. As shown in Figure 4, performance

Table 4: Observation success across repeated exposure iterations.

Iteration	Successful / partial	Unsuccessful	Total
Iteration 1	182	178	360
Iteration 2	218	142	360
Iteration 3	240	120	360
Total	640	440	1080

improved across iterations, confirming H4 and demonstrating that shoulder surfing can be strengthened through short-term repeated exposure.

A chi-square test indicated a significant association between iteration and success,

$$\chi^2(2, N = 1080) = 19.73, p < .001$$

The effect size was small-to-medium (Cramer's $V = .14$), reflecting a meaningful but not dominant learning effect between the first and third observation.

4. Summary and Discussion

4.1. Summary of Findings

This paper examined the security risks of shoulder-surfing attacks while using contemporary PIN-based authentication devices (ATM keypad and touchscreen terminal). A total of 1,080 attempts to reveal the PIN value were conducted across various scenarios to capture the key situational, behavioral, and demographic variables influencing attacker performance. The results confirmed that lighting conditions, shielding type, observer age, and repeated exposure all significantly affect the probability of successful PIN reconstruction.

Lighting conditions influenced observation success, with the lowest accuracy recorded under direct sunlight and higher rates in shaded or indoor environments, suggesting that glare and contrast reduction hinder observers' ability to distinguish keypad movements. Shielding proved to be the most decisive protective factor: full visibility allowed over 75% success, while a fixed hood reduced the rate to below 40%. These findings support continued

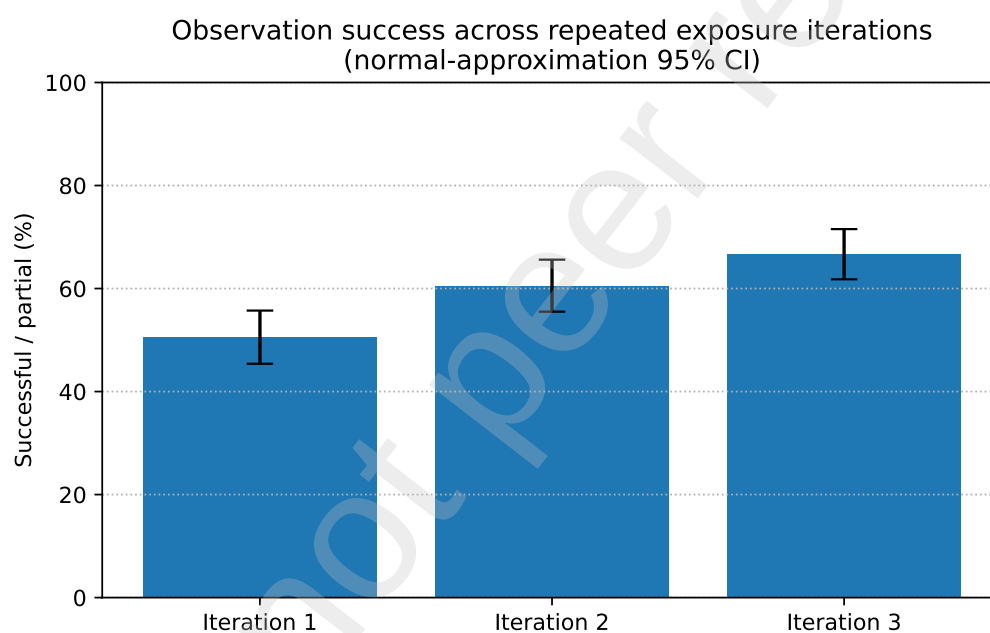


Figure 4: Observation success across repeated exposure iterations (successful/partial: 50.6%, 60.6%, 66.7%; normal-approximation confidence intervals).

integration of mechanical or physical countermeasures in public self-service terminals.

Age and prior experience were also important determinants of success, in line with earlier findings (Kwon et al., 2013). Younger observers with technical or financial backgrounds exhibited higher accuracy, indicating that cognitive agility, visual acuity, and familiarity with input devices enhance shoulder-surfing capabilities. Repeated exposure improved performance, increasing success from 50.6% in initial trials to 66.7% by the third iteration.

4.2. Comparison with Prior Work

Compared to prior published work, our observed success rates fall within the upper range of known results for PIN observation. For instance, Bâce, M., Saad, A., Khamis, M., Schneegass, S., & Bulling, A. (2022) report a mean edit distance of 0.73 across various angles and distances, while Schaub et al. (2012) and Aviv, A. J., Wolf, F., & Kuber, R. (2018) document full-PIN reconstruction rates of 40–80% depending on occlusion and grip. Our results demonstrate similar or higher accuracy, consistent with the controlled, single-position design and prior evidence that repeated exposure rapidly improves observer proficiency. These findings reinforce the vulnerability of PIN entry even under adverse environmental conditions.

Mechanism-level explanation. The observed effects are consistent with three complementary perceptual mechanisms. First, glare and reduced contrast in direct sunlight likely degrade key cues (finger–key contact events, edge definition, and micro-motions), lowering discriminability even when the keypad is fully visible. Second, occlusion (hand cover or a fixed hood) introduces trajectory ambiguity by removing critical portions of the finger path and spatial reference points, forcing observers to infer digits from incomplete motion fragments. Third, repeated exposure plausibly supports rapid strategy refinement—including chunking of common movement patterns and anticipatory allocation of attention to informative regions of the keypad—which improves inference accuracy despite unchanged physical viewing geometry.

4.3. Practical Implications and Design Recommendations

Design implications (if–then guidance).

1. **If** a device is deployed in a public queueing context (ATMs, kiosks, countertop payment terminals), **then** prioritize enclosure geometry

that reduces top-down and rear visibility without increasing user effort. Concretely, increase effective hood depth, add keypad recess, and adjust keypad/screen tilt to minimize line-of-sight from common attacker positions while preserving comfortable wrist posture and clear target acquisition.

2. **If** the interface must remain legible across outdoor glare, indoor reflections, and nighttime illumination, **then** implement glare-robust rendering: adaptive brightness/contrast management, high-contrast key boundaries, and (where feasible) anti-reflection surface treatments. Treat sunlight and low-light conditions as first-class test cases in usability evaluation, because visibility changes can both hinder users and alter the cues available to observers.
3. **If** an attacker can obtain repeated observations (e.g., shared terminals, habitual users, or short retry sequences), **then** adopt interaction policies that explicitly assume learning: rate-limit sensitive retries, introduce brief attention-diverting micro-interactions, and consider randomized keypad layouts *only* when their usability and accessibility costs are acceptable (e.g., provide stable spatial anchors, sufficient target sizes, and alternatives for users who rely on consistency, including many older adults and users with motor or cognitive constraints).

Finally, designers should explicitly consider heterogeneous user populations and accessibility constraints: countermeasures that add fine motor demands, complex gestures, or high cognitive workload can create usability barriers—especially for older adults and time-pressured transactions—and may undermine real-world adoption. Examples include requiring elaborate two-handed shielding gestures, reducing target sizes or increasing precision demands on key presses, and imposing strict timeouts or high interaction tempo under queue pressure. The most robust solutions are therefore those that *embed* protection into the interaction and device form factor (e.g., enclosure geometry, glare-robust rendering, and policy-level controls) while maintaining fast, low-effort completion for everyday users.

4.4. Limitations

While the experiment systematically isolated key factors, several limitations must be acknowledged. First, observers were positioned in an optimal viewing location with unobstructed visibility. Prior work shows that observation angle and distance can substantially affect success (Bâce, M., Saad,

A., Khamis, M., Schneegass, S., & Bulling, A. , 2022; Aviv, A. J., Wolf, F., & Kuber, R. , 2018), and our results therefore represent upper-bound estimates of attacker capability. Real-world attackers often face less favorable viewing geometries, occlusions, crowding, or movement, which may reduce effective accuracy.

Second, participants were instructed to focus solely on reconstructing the PIN, whereas field studies indicate that real-world shoulder surfing is often opportunistic rather than deliberate (Eiband et al., 2017; Schneegass et al., 2022). The high success rates observed in the present study reflect motivated attackers rather than casual observers.

Third, although demographic differences (particularly age and experience) were included, other potentially influential characteristics—such as visual acuity, height differences between attacker and victim, or cognitive workload—were not systematically controlled. As noted by Bâce, M., Saad, A., Khamis, M., Schneegass, S., & Bulling, A. (2022), such factors can meaningfully influence visibility and performance but remain challenging to model.

Fourth, our selection of devices is intended to represent two common PIN-entry form factors (a mechanical ATM-style keypad and a touchscreen payment terminal). We do *not* claim that the observed rates reflect the quality of any specific commercial product design; instead, the results should be interpreted as evidence about interaction-level and form-factor-level vulnerabilities under the tested visibility and occlusion conditions.

Fifth, the study examined only four-digit PIN entry, whereas other authentication methods (graphical passwords, pattern locks, or hybrid PIN-gesture systems) may exhibit different vulnerability profiles. Future work should extend the experimental design to multiple authentication modalities and incorporate real-world variability in device type, lighting transitions, and user movement.

Finally, although the study was not powered to formally test higher-order interactions among variables such as lighting $\times$ shielding or shielding $\times$ observer expertise, the observed patterns suggest that such interactions may exist. For example, the reduction in visibility under direct sunlight may compound the protective effect of physical shielding, and experienced observers may compensate more effectively for adverse lighting. These possibilities align with established theories of perceptual load, cue integration, and compensatory attention strategies. Future research with larger samples or mixed-effects models could therefore examine how environmental and be-

havioral factors jointly shape real-time credential inference.

5. Conclusion

In this study, we systematically evaluated how environmental, perceptual, and behavioral factors shape the likelihood and severity of shoulder-surfing attacks during PIN entry. Across 1,080 controlled observations, all four examined variables—lighting conditions, shielding, observer demographics, and repeated exposure—showed statistically significant effects. The findings confirm that shoulder surfing is not merely an opportunistic privacy breach but a perceptual skill that can improve with repeated exposure. This underscores the vulnerability of widely deployed PIN-entry authentication, particularly in public or semi-public environments.

From an applied human-factors perspective, the results highlight three key implications. First, physical shielding—whether user-initiated or embedded into device enclosures—remains the most effective low-effort defense. Even simple hand-shielding reduces successful observations by half, while fixed hoods typical of ATMs lower accuracy below 40 %. Second, designers of PIN-entry devices, payment terminals, banking interfaces, and mobile devices should account for perceptual constraints such as glare, viewing geometry, and attentional limits, incorporating adaptive shading, contrast management, or dynamic keypad layouts where feasible. Third, because attackers learn quickly, relying solely on user vigilance is insufficient; effective defenses must assume repeated exposure and trained adversaries.

Overall, this research reinforces the need for authentication mechanisms that integrate ergonomic protection, environmental robustness, and cognitive resilience. Future work should extend these findings to emerging form factors, multimodal authentication, and real-world ecological settings, supporting the development of secure, resilient, and user-centered interfaces for everyday financial and mobile interactions.

Declarations

Declaration of competing interest. The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Funding. Funding information is provided in the separate Title Page and/or the submission system to preserve double anonymized peer review.

CRedit authorship contribution statement. The CRedit statement is provided in the separate Title Page and/or the submission system to preserve double anonymized peer review.

Declaration of generative AI and AI-assisted technologies. During the preparation of this work the author(s) used AI-assisted tools for language editing and clarity improvements. No generative AI or AI-assisted tools were used to create or alter figures, images, or artwork. After using these tools, the author(s) reviewed and edited the content as needed and take(s) full responsibility for the content of the published article.

Data availability

The research data supporting this study are provided for review as supplementary material (*ExperimentalData.xlsx*). In the final published version, the dataset will be deposited in a public research-data repository and cited/linked in the article, in line with the journal's research-data guidance.

References

- Leslie Lamport, *TEX: a document preparation system*, Addison Wesley, Massachusetts, 2nd edition, 1994.
- Adams, A., & Sasse, M. A. *Users are not the enemy*. Communications of the ACM, 42(12), 40–46.
- Alhothaily, A., Hu, C., Alrawais, A., Song, T., & Cheng, X. (2017). *A secure and practical authentication scheme using personal devices*. *IEEE Access*, 5, 11677–11687. <https://doi.org/10.1109/access.2017.2717862>
- Aviv, A. J., et al. (2015). *Understanding visual perceptions of mobile authentication*. Proceedings of the USENIX Symposium on Usable Privacy and Security, 1–16.
- Aviv, A. J., Budzitowski, D., & Kuber, R. (2017). *Is bigger better? Comparing user-generated passwords on mobile devices and PCs*. Proceedings of MobileHCI 2017, 531–541.

- . Aviv, A. J., Wolf, F., & Kuber, R. (2018) *Comparing video-based shoulder surfing with live simulation*. ACSAC '18.
- Bâce, M., Saad, A., Khamis, M., Schneegass, S., & Bulling, A. (2022) *PrivacyScout: Assessing vulnerability to shoulder surfing on mobile devices*. Proceedings on Privacy Enhancing Technologies.
- Binbeshr, F. S. S. (2022). *A Secure Pin-Entry Method Resistant to Shoulder-Surfing and Recording Attacks* (Doctoral dissertation), University of Malaya, Malaysia.
- Binbeshr, F., Por, L. Y., Kiah, M. L. M., Zaidan, A. A., & Imam, M. (2023). *Secure PIN-entry method using one-time PIN (OTP)*. *IEEE Access*, 11, 18121–18133. <https://doi.org/10.1109/access.2023.3243114>
- Bošnjak, L., & Brumen, B. (2019). *Shoulder surfing: From an experimental study to a comparative framework*. *International Journal of Human-Computer Studies*, 130, 1–20. <https://doi.org/10.1016/j.ijhcs.2019.04.003>
- Brudy, F. (2014). *Is Anyone Looking? Mitigating Shoulder Surfing on Public Displays through Awareness and Protection*. Master's thesis, LMU München, Department for Informatics.
- Chefrour, D., Sedira, Y., & Chabbi, S. (2024). *An intersection attack on the CirclePIN smartwatch authentication mechanism*. *IEEE Internet of Things Journal*, 11(7), 12485–12494. <https://doi.org/10.1109/jiot.2023.3333964>
- Chen, C.-Y., Lin, B.-Y., Wang, J., & Shin, K. G. (2019). *Keep Others from Peeking at Your Mobile Device Screen!* In *Proceedings of the 25th Annual International Conference on Mobile Computing and Networking (MobiCom '19)*.
- Darling, D., Liu, Y., & Li, Q. (2022, November). *Privacy protection against shoulder surfing in mobile environments*. In *International Conference on Mobile and Ubiquitous Systems: Computing, Networking, and Services* (pp. 133–152). Cham: Springer Nature Switzerland.
- De Luca, A., et al. (2010). *Look into my eyes!: Can you guess my password?* *Proceedings of NordiCHI 2010*, 111–120.

- Eiband, M., et al. (2017). *Understanding shoulder surfing on mobile devices: A survey of user experiences. Proceedings of CHI 2017 Extended Abstracts*, 5080–5087.
- Farzand, H., Bhardwaj, K., Marky, K., & Khamis, M. (2021). *The interplay between personal relationships and shoulder surfing mitigation. Proceedings of MuC '21*.
- Gong, J., Akande, O. N., Lin, C.-C., & Agarwal, S. (2024). *A dynamic and incremental graphical grid authentication technique for mobile and web applications. IEEE Access*, 12, 174831–174849. <https://doi.org/10.1109/access.2024.3503637>
- Harbach, M., Fahl, S., & Smith, M. (2014). *It's a Hard Lock Life: A Field Study of Smartphone (Un)Locking Behavior and Risk Perception. Proceedings of SOUPS 2014*.
- Herland, K., Hämmäinen, H., Kekolahti, P., et al. (2016). *Information security risk assessment of smartphones using Bayesian networks. Journal of Cyber Security and Mobility*, 4(2), 65–86. <https://doi.org/10.13052/jcsm2245-1439.424>
- Johansson, G. (1973). Visual perception of biological motion and a model for its analysis. *Perception & Psychophysics*, 14, 201–211.
- Kaczmarek, T., et al. (2016). *Turning heads: The impact of viewing angle and screen brightness on visual privacy. Proceedings of CHI 2016 Extended Abstracts*, 1659–1666.
- Khamis, M., Alt, F., & Bulling, A. (2018). *The past, present, and future of gaze-enabled handheld mobile devices. Proceedings of the ACM on Interactive, Mobile, Wearable and Ubiquitous Technologies*, 2(1), 1–33.
- Khan, H., Hengartner, U., & Vogel, D. (2018, April). *Evaluating attack and defense strategies for smartphone PIN shoulder surfing*. In *Proceedings of the 2018 CHI Conference on Human Factors in Computing Systems* (pp. 1–10).
- Kružiková, A., Knapová, L., Gabrhelík, O., Šmahel, D., Dědková, L., Matyáš, V., ... & Šmahelová, M. (2020). *User Testing of Mobile Banking Authentication Methods: UX Testing, User Interviews, and Quantitative Survey*. Technical report for TA ČR project Innovation and adaptation of

- authentication technologies for secure digital environment (TL01000207). https://irtis.muni.cz/media/3221965/usertesting_tacrreport_2020r.pdf
- Ku, Y., Park, L. H., Shin, S., & Kwon, T. (2019). *Draw it as shown: Behavioral pattern lock for mobile user authentication*. *IEEE Access*, 7, 69363–69378. <https://doi.org/10.1109/access.2019.2918647>
- Kwon, T. & Hong, J. (2015). *Analysis and Improvement of a PIN-Entry Method Resilient to Shoulder-Surfing and Recording Attacks*. *IEEE Transactions on Information Forensics and Security*, 10(2), 278–292. <https://doi.org/10.1109/tifs.2014.2374352>
- Kwon, T., Shin, S., & Na, S. (2013). Covert attentional shoulder surfing: Human adversaries are more powerful than expected. *IEEE Transactions on Systems, Man, and Cybernetics: Systems*, 44(6), 716–727.
- Lopez, N., Rodriguez, M., Fellegi, C., Long, D., & Schwarz, T. (2015). *Even or odd: A simple graphical authentication system*. *IEEE Latin America Transactions*, 13(3), 804–809. <https://doi.org/10.1109/tla.2015.7069108>
- McAfee. (2025, May 13). *What is shoulder surfing?*
- MITRE. (2025). *CAPEC-508: Shoulder Surfing*. *MITRE Common Attack Pattern Enumeration and Classification (CAPEC)*. (accessed June 2025).
- Nizamani, S. Z., Hassan, S. R., Shaikh, R. A., Abozinadah, E. A., & Mehmood, R. (2021). *A novel hybrid textual-graphical authentication scheme with better security, memorability, and usability*. *IEEE Access*, 9, 51294–51312. <https://doi.org/10.1109/access.2021.3069164>
- NordVPN. (2025, May 13). *What is shoulder surfing, and how can you avoid it?*
- Nyang, D., Kim, H., Lee, W., Kang, S. B., Cho, G., Lee, M. K., & Mohaisen, A. (2018). Two-thumbs-up: Physical protection for pin entry secure against recording attacks. *Computers & Security*, 78, 1–15.
- Por, L. Y., Ng, I. O., Chen, Y.-L., Yang, J., & Ku, C. S. (2024). *A systematic literature review on the security attacks and counter-measures used in graphical passwords*. *IEEE Access*, 12, 53408–53423. <https://doi.org/10.1109/access.2024.3373662>

- Schaub, F., Deyhle, R., & Weber, M. (2012). *Password entry usability and shoulder surfing susceptibility on different smartphone platforms*. In *Proceedings of the 11th International Conference on Mobile and Ubiquitous Multimedia (MUM 2012)*.
- Schneegass, S., Saad, A., Heger, R., Delgado Rodriguez, S., Poguntke, R., & Alt, F. (2022). *An investigation of shoulder surfing attacks on touch-based unlock events*. *Proceedings of the ACM on Human-Computer Interaction*, 6(MHCI), 1–14.
- Shahzad, M., Liu, A. X., & Samuel, A. (2017). *Behavior-based human authentication on touch screen devices using gestures and signatures*. *IEEE Transactions on Mobile Computing*, 16(10), 2726–2741. <https://doi.org/10.1109/tmc.2016.2635643>
- Sosa Valles, P. A., Villalobos-Serrano, J. G., Martínez-Peláez, R., García, V., Parra Michel, J. R., et al. (2018). *My personal images as my graphical password*. *IEEE Latin America Transactions*, 16(5), 1516–1523. <https://doi.org/10.1109/tla.2018.8408449>
- Sun, H.-M., Chen, S.-T., Yeh, J.-H., & Cheng, C.-Y. (2018). *A shoulder-surfing-resistant graphical authentication system*. *IEEE Transactions on Dependable and Secure Computing*, 15(2), 180–193. <https://doi.org/10.1109/tdsc.2016.2539942>
- Sun, Y., Wang, H., & Zhang, Y. (2016). *On the security of pattern-based Android unlock schemes*. *Proceedings of the ACM Symposium on Information, Computer and Communications Security*, 104–116.
- Tari, F., Ozok, A., & Holden, S. (2006). *A comparison of perceived and real shoulder-surfing risks between alphanumeric and graphical passwords*. *Proceedings of SOUPS 2006*, 56–66.
- Verghese, P. (2001). *Visual search and attention: A signal detection theory approach*. *Vision Research*, 41(12), 1673–1684.
- Wan, T., Zhang, L., Xu, Y., Guo, Z., & Gao, B. (2024). *Analysis and design of efficient authentication techniques for password entry with the Qwerty keyboard for VR environments*. *IEEE Transactions on Visualization and Computer Graphics*, 30(11), 7075–7085. <https://doi.org/10.1109/tvcg.2024.3456195>

- Wiese, O., & Roth, V. (2015). *Pitfalls of shoulder surfing studies*. *NDSS Symposium 2015 (USEC workshop)*.
- Wu, C., Cao, H., Xu, G., Zhou, C., & Sun, J. (2024). *It's all in the touch: Authenticating users with HOST gestures on multi-touch screen devices*. *IEEE Transactions on Mobile Computing*, 23(10), 10016–10030. <https://doi.org/10.1109/tmc.2024.3371014>
- von Zezschwitz, E., Dunphy, P., & De Luca, A. (2015). *Patterns in the wild: A field study of the usability of pattern-based authentication*. *Proceedings of MobileHCI 2015*, 1–10.
- Zhao, Y., Gao, R., Liu, S., Xie, L., & Wu, J. (2021). *Device-free secure interaction with hand gestures in WiFi-enabled IoT environment*. *IEEE Internet of Things Journal*, 8(7), 5619–5631. <https://doi.org/10.1109/jiot.2020.3032623>
- Zhou, L., Wang, K., Lai, J., & Zhang, D. (2023). *A comparison of a touch-gesture- and a keystroke-based password method: Toward shoulder-surfing resistant mobile user authentication*. *IEEE Transactions on Human-Machine Systems*, 53(2), 303–314. <https://doi.org/10.1109/thms.2023.3236328>
- Zhu, B. B., Yan, J., Bao, G., Yang, M., & Xu, N. (2014). *Captcha as graphical passwords — A new security primitive based on hard AI problems*. *IEEE Transactions on Information Forensics and Security*, 9(6), 891–904. <https://doi.org/10.1109/tifs.2014.2312547>
- Zhu, H., Hu, J., Chang, S., & Lu, L. (2017). *ShakeIn: Secure user authentication of smartphones with single-handed shakes*. *IEEE Transactions on Mobile Computing*, 16(10), 2901–2912. <https://doi.org/10.1109/tmc.2017.2651820>